

Literature Review and Methodology

Deliverable

Project Title : Network Segmentation Effectiveness for PCI DSS Scope Reduction
Deliverable Status Follow-up Deliverable III
Name : Mr. Thy Dayuth
Advisor : Mr. Meas Sothearath

1. Introduction and Problem Statement.....	2
2. Literature Review.....	2
2.1. PCI DSS Compliance and Scope Reduction.....	2
2.2. Secure Network Architecture & Segmentation Controls.....	2
2.2.1. DMZ Isolation :.....	2
2.2.2. Micro-Segmentation and Inter-VLAN Routing :.....	2
2.3. Application Security and Secure Cardholder Data Processing.....	3
2.3.1. In-Transit Security :.....	3
2.3.2. At-Rest Protection and Tokenization :.....	3
2.4. System Methodology and Technical Framework.....	3
2.5. Network Diagram and Infrastructure Segmentation.....	3
2.5.1 IP Table.....	3
2.5.2. Network Diagram.....	5
2.6. Data Persistence and Cryptography Architecture.....	6
2.6.1. Customer Data.....	6
2.6.2. Transaction Payload Cryptography :.....	6
2.7. Infrastructure Utilities and Log Collection Strategy.....	7
2.8. Inside CDE Processing Flows.....	7
1. Transaction Entry (POS – DMZ).....	7
2. Application Processing (Application Server).....	7
3. Encryption & Tokenization (KMS).....	7
4. Return Secure Data.....	7
5. Database Storage (PostgreSQL).....	8
3. Project Implementation Plans.....	8

1. Introduction and Problem Statement

PCI DSS compliance is essential for any organization that processes, stores, or transmits cardholder data (CHD). However, applying it across an entire corporate network can increase audit complexity, operational cost, and attack surface. Example :

- Increased audit scope across all systems
- Higher infrastructure and compliance costs
- Larger attack surface for attackers
- More complex firewall and access control management
- Increased monitoring and logging workload

The project evaluates how network segmentation can reduce PCI DSS scope by isolating the Cardholder Data Environment (CDE) from the rest of the corporate network, lowering the number of systems under strict compliance controls while improving security.

2. Literature Review

2.1. PCI DSS Compliance and Scope Reduction

PCI DSS defines audit scope based on where cardholder data and sensitive authentication data are stored, processed, or transmitted. Flat networks can expose unrelated systems to the same risks as payment systems.

Network segmentation separates in-scope and out-of-scope systems. It does not lower security for excluded systems, but it allows stronger protection around the Cardholder Data Environment.

2.2. Secure Network Architecture & Segmentation Controls

Robust network segmentation uses a defense-in-depth approach with perimeter firewalls, internal firewalls, WAFs, and VLANs.

2.2.1. DMZ Isolation :

Inbound payment traffic from external sources, such as POS systems, is first routed to a restricted DMZ where firewalls and WAFs filter malicious traffic before reaching internal systems.

2.2.2. Micro-Segmentation and Inter-VLAN Routing :

Different network zones are separated using VLANs and firewall ACLs. Traffic between networks must pass through internal firewalls that enforce a default deny policy.

2.3. Application Security and Secure Cardholder Data Processing

Modern compliance frameworks require network isolation together with application-level data protection using encryption, tokenization, and centralized key management systems (KMS).

2.3.1. In-Transit Security :

Cardholder data transmitted across networks should use TLS 1.2 or higher to protect against interception and man-in-the-middle attacks.

2.3.2. At-Rest Protection and Tokenization :

Storing raw card numbers increases compliance risk. Sensitive data should be encrypted using AES-256 and replaced with tokens, while only masked PAN data is stored in the database to prevent cleartext exposure.

2.4. System Methodology and Technical Framework

The proposed methodology uses a segmented network architecture to validate PCI DSS scope isolation through network scanning, data-flow testing, and configuration auditing.

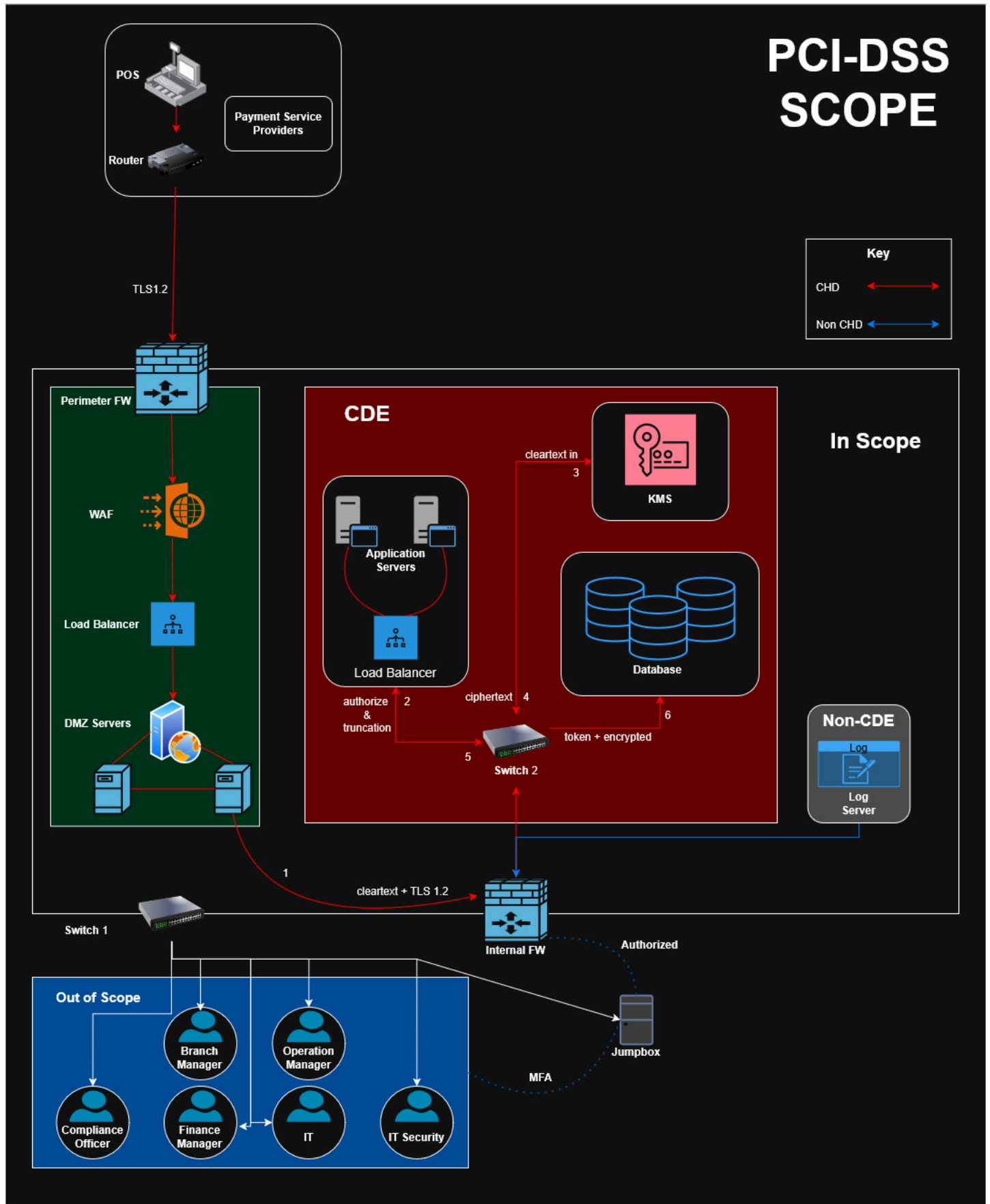
2.5. Network Diagram and Infrastructure Segmentation

2.5.1 IP Table

ID	Name / Component	Vlan	IP / Subnet
Retailer			
1	Retailer POS	VLAN 10 (Store)	192.168.10.20/24
2	Retailer Router	VLAN 10 (Store)	192.168.10.1/24
Firewalls & DMZ			
3	Perimeter Firewall (External)	-	192.168.10.254/24
4	Perimeter Firewall (Internal)	VLAN 20 (DMZ)	10.0.10.1/24
5	Internal Firewall (CDE Facing)	-	10.100.1.1/24
6	DMZ	VLAN 20 (DMZ)	10.0.10.10/24
Switches			
7	Switch 1	VLAN 50	10.50.1.2/24
8	Switch 2	VLAN 100	10.100.1.2/24

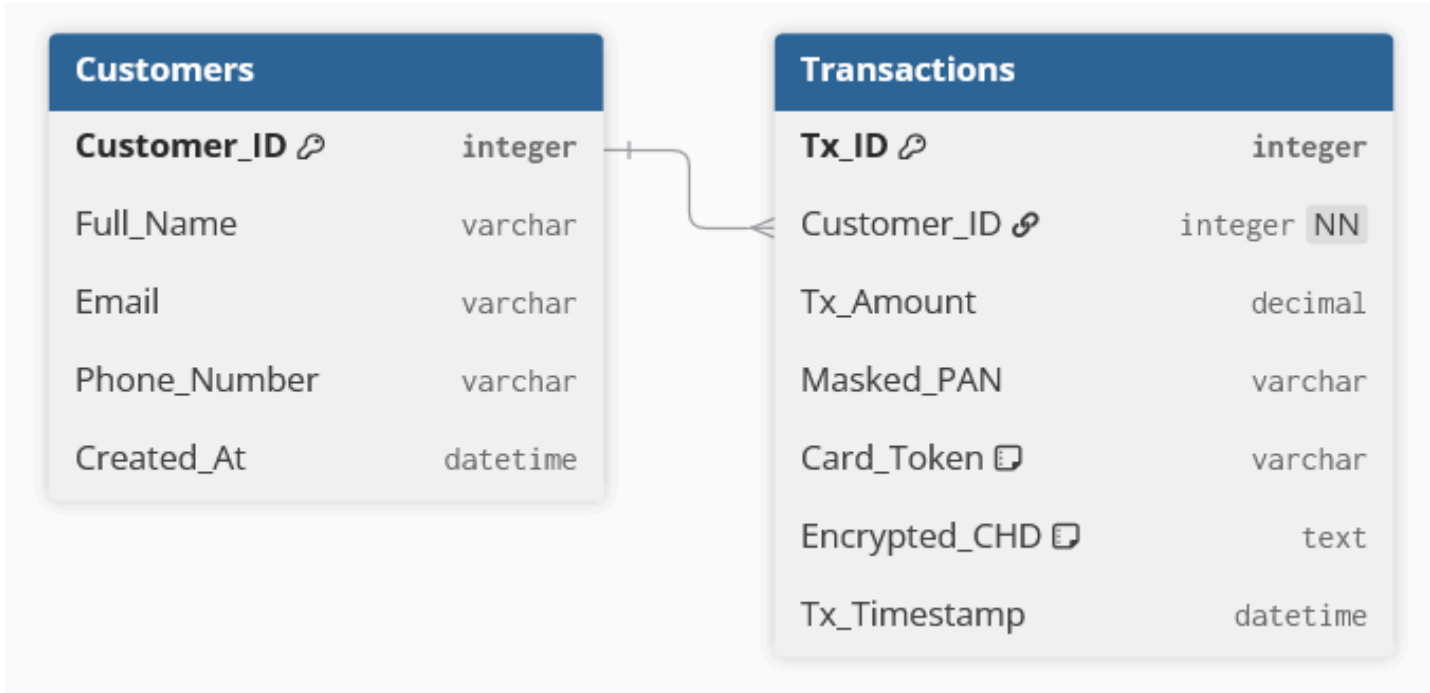
Cardholder Data Environment			
9	Application Server	VLAN 110	10.100.10.10/24
10	Key Management System (KMS)	VLAN 120	10.100.20.10/24
11	Database	VLAN 130	10.100.30.10/24
Utilities			
12	Jumpbox	VLAN 99	10.50.99.10/24
13	Log Server	VLAN 200	10.200.10.10/24
Departments			
14	Branch Manager	VLAN 51	10.50.51.10/24
15	Operation Manager	VLAN 52	10.50.52.10/24
16	Compliance officer	VLAN 53	10.50.53.10/24
17	Finance Manager	VLAN 54	10.50.54.10/24
18	IT	VLAN 55	10.50.55.10/24
19	IT Security	VLAN 56	10.50.56.10/24

2.5.2. Network Diagram



2.6. Data Persistence and Cryptography Architecture

To support security compliance, a PostgreSQL database schema is designed to separate user authentication data from transaction records and reduce cleartext data exposure.



2.6.1. Customer Data

Users are authenticated through the **Customers** table, which stores only essential identity information and avoids storing sensitive authentication credentials directly. Example :

Customer_ID	Full_Name	Email	Phone_Number	Created_At
1	Srey Neang	neang@mail.com	+85512345604	2026-02-15 17:40:00

2.6.2. Transaction Payload Cryptography :

The **Transactions** table minimizes exposure of cardholder data by masking PAN values and using tokenization via KMS. Full card data is encrypted using AES-256 before storage. Example :

Tx_ID	Customer_ID	Tx_Amount	Masked_PAN	Card-Token	Encrypted_C HD	Tx_Timestam p
1001	1	120.50	*****42 42	tok_a91f33	gAAAAABkX 1...Q29udGVu dDE=	2026-03-01 10:10:00

2.7. Infrastructure Utilities and Log Collection Strategy

To ensure compliance, supporting controls include anti-malware protection, NTP for time synchronization, and a private DNS service.

Centralized logging is collected through an isolated log server (VLAN 200) to monitor security and system activity :

- **Firewalls** : Log traffic events and configuration changes
- **Jumpbox** : Records login attempts, session duration, and authentication results
- **Application Server** : Tracks user activity, errors, and API requests
- **KMS** : Logs key generation and access events
- **Database Server** : Records queries, transactions, and access logs

2.8. Inside CDE Processing Flows

1. Transaction Entry (POS – DMZ)

- Customer pays at Retailer POS (VLAN 10)
- Transaction data is encrypted using TLS 1.2
- Sent to DMZ Server (VLAN 20)
- Internal firewall validates and forwards it to the application layer

2. Application Processing (Application Server)

- Application Server (VLAN 110) receives the payload
- Data is split immediately in memory:
 - SAD Verified and Disposed Immediately
 - Masking PAN (Example : *****4242)
 - Other card data prepared for encryption

3. Encryption & Tokenization (KMS)

- Application Server sends sensitive data to KMS (VLAN 120)
- KMS performs:
 - AES-256 encryption → produces Encrypted_CHD
 - Tokenization → produces Card_Token
 - Raw keys never leave the KMS

4. Return Secure Data

- KMS returns:
 - Card_Token
 - Encrypted_CHD

- Application Server discards any remaining raw card data from memory

5. Database Storage (PostgreSQL)

Data is stored in VLAN 130 PostgreSQL database:

- Customers Table: stores identity data only (name, email, phone)
- Transactions Table: stores only secure artifacts:
 - Tx_Amount
 - Masked_PAN
 - Card_Token
 - Encrypted_CHD
 - Timestamp

3. Project Implementation Plans

ID	Task Name	Duration
Category A: Core Network & Infrastructure		
A01	Configure Switch 1 (Department VLAN)	1
A02	Configure Switch 2 (CDE segmentation)	1
A03	Configure Firewalls Inbound and Outbound	1
A04	Provision Perimeter Firewall Vlan10, Vlan20	2
A05	Provision Internal Firewall CDE and Logs	2
Category B: Security Controls & Firewall Rules		
B01	ACLs to isolate each department	1
B02	Configure Switch 1 to have all OOS to be able to reach Jumpbox	2
B03	Implement Tunnel TLS1.2 from Retailer to DMZ	2
B04	Configuring App Server to exclusively bidirectional to KMS & DB	2
B05	Enforce Deny By Default to firewalls and Switch 1	1
Category C: Systems & Identity Access Management (IAM)		
C01	Deploy Jumpbox and have static IP of it (10.50.99.10)	1
C02	Hardening Jumbox server	1
C03	Implementing MFA to the Jumpbox server	1
C04	Deploy Logging Server indirect pipeline	3
Category D: Database & Application Development		

D01	Provisioning Database Roles and Set up PostgreSQL	1
D02	Initialize Schema and Create storing database	1
D03	Integrating Key Management System	1
D04	Develop Application Server to catch inbound from DMZ	3
D05	Integrate Application Server to handle outbound API requests to KMS	1
D06	Program the Application Server data persistence layer to write masked PANs, tokens, and encrypted ciphertext payloads to the DB	1
D07	POS transaction payload generation script development	1
Category E: Integration, Testing & End-to-End Validation		
E01	Conduct Nmap Scan to verify the isolation	1
E02	MFA verification integration	1
E03	Prove the default deny on CDE and auto reject from KMS and DB if not originate from Application Server	1
E04	Simulation : POS purchase, trace it through the DMZ and App Server, and confirm tokenized storage in the DB	1
E05	Audit Log Validation : login, firewall drops, ssh remote, DB queries	1
Category F: Documentation & Reporting (Final Phase)		
F01	Finalizing Report	7